

CYBERSECURITY 266IT

Progetto Threat Intelligence e IOC

S9 L5

Andrea Calabretta

SOMMARIO

1. Traccia esercizio Report S9 L5.....	3
2. Introduzione alla Threat Intelligence e agli IOC	4
2.1 Cos'è la Threat Intelligence	4
2.2 Cosa sono gli Indicatori di Compromissione (IOC)	4
3. Analisi della Cattura di Rete	5
3.1 Contesto e Infrastruttura	5
3.2 Il Three-Way Handshake TCP — Breve Richiamo	6
3.3 Identificazione degli IOC	6
3.3.1 IOC #1 — Port Scan TCP Connect su 1024 Porte.....	6
3.3.2 IOC #2 — Pattern Temporale della Scansione	8
3.3.3 IOC #3 — Host Announcement NetBIOS	8
3.4 Correlazione degli IOC con il Vettore di Attacco	8
4. Ipotesi sui Potenziali Vettori di Attacco.....	9
4.1 Vettori ad Alto Rischio.....	9
4.2 Catena di Attacco Ipotetica	9
5. Raccomandazioni di Mitigazione.....	10
5.1 Azioni Immediate.....	10
5.2 Hardening del Sistema Target	10
5.3 Difesa in Profondità e Prevenzione Futura.....	10
6. Conclusioni	11

1. Traccia esercizio Report S9 L5

Traccia: Esercizio Threat Intelligence & IOC

Durante la lezione teorica, abbiamo visto la Threat Intelligence e gli indicatori di compromissione. Abbiamo visto che gli IOC sono evidenze o eventi di un attacco in corso, oppure già avvenuto.

Per l'esercizio pratico di oggi, trovate in allegato una cattura di rete effettuata con Wireshark. Analizzate la cattura attentamente e rispondere ai seguenti quesiti:

- Identificare ed analizzare eventuali IOC, ovvero evidenze di attacchi in corso
- In base agli IOC trovati, fate delle ipotesi sui potenziali vettori di attacco utilizzati
- Consigliate un'azione per ridurre gli impatti dell'attacco attuale ed eventualmente un simile attacco futuro

2. Introduzione alla Threat Intelligence e agli IOC

Prima di entrare nel vivo dell'analisi pratica, ritengo utile richiamare brevemente i concetti teorici che fanno da sfondo a questo esercizio, perché credo che averli chiari aiuti moltissimo a capire cosa stiamo cercando quando guardiamo una cattura di rete.

2.1 Cos'è la Threat Intelligence

La Threat Intelligence, o Cyber Threat Intelligence (CTI), è l'insieme di informazioni raccolte, elaborate e contestualizzate riguardanti le minacce informatiche esistenti o potenziali. L'obiettivo principale è quello di trasformare dati grezzi — come indirizzi IP sospetti, firme di malware o comportamenti anomali sulla rete — in conoscenza actionable, ovvero in informazioni che un team di sicurezza può usare concretamente per prendere decisioni: bloccare un indirizzo, aggiornare una regola del firewall, o avviare un'indagine.

La Threat Intelligence si articola tipicamente su tre livelli: strategico (destinato al management, descrive il panorama delle minacce ad alto livello), tattico (descrive le tecniche e le tattiche degli attaccanti, spesso mappate su framework come MITRE ATT&CK) e operativo (informazioni immediate e tecniche su attacchi in corso o imminenti). In questo esercizio ci muoviamo prevalentemente sul piano operativo, analizzando una cattura di traffico reale per identificare comportamenti sospetti.

2.2 Cosa sono gli Indicatori di Compromissione (IOC)

Gli Indicatori di Compromissione, comunemente noti con l'acronimo IOC (dall'inglese Indicators of Compromise), sono prove o tracce digitali che indicano che un sistema o una rete è stata compromessa, o che è attualmente sotto attacco. Si tratta di artefatti forensi osservabili — presenti in log di sistema, catture di rete, file system o memoria volatile — che segnalano un'attività anomala o malevola.

Gli IOC possono assumere forme molto diverse: indirizzi IP o domini associati a infrastrutture di Command & Control, hash di file corrispondenti a malware noti, chiavi di registro modificate, user-agent insoliti nelle richieste HTTP, o — come nel nostro caso — pattern di traffico di rete anomali come una scansione sistematica delle porte. Identificare un IOC non significa necessariamente che un attacco sia andato a buon fine, ma certamente indica che qualcosa di sospetto sta accadendo e che è necessario approfondire.

Nel contesto di questa analisi, utilizzeremo gli IOC come punto di partenza per ricostruire il possibile vettore di attacco e formulare raccomandazioni di mitigazione.

3. Analisi della Cattura di Rete

3.1 Contesto e Infrastruttura

La cattura analizzata, denominata Cattura_U3_W1_L5.pcapng, è stata acquisita tramite Wireshark in un ambiente di laboratorio virtualizzato. Dalla lettura dei pacchetti emergono immediatamente due host principali coinvolti nel traffico:

Host	Indirizzo IP	Ruolo
Attaccante (Kali Linux)	192.168.200.100	Macchina sorgente del traffico sospetto
Vittima (Metasploitable 2)	192.168.200.150	Target della scansione

Figura 1 — Infrastruttura di rete rilevata dalla cattura

La cattura contiene complessivamente 2083 frame, distribuiti su un arco temporale di circa 37 secondi. La quasi totalità del traffico è TCP (2078 frame), con la presenza di 4 pacchetti ARP e un singolo datagramma UDP/NetBIOS. Questa distribuzione è di per sé già un segnale interessante: in una rete normale mi aspetterei una varietà di protocolli molto più ampia, non un traffico così monotono e focalizzato su TCP.

La schermata seguente mostra la cattura aperta in Wireshark, con il traffico non filtrato. È possibile già a colpo d'occhio notare la presenza di righe evidenziate in rosso corrispondenti ai pacchetti RST-ACK, e alcune in blu chiaro per i pacchetti SYN, un pattern visivo caratteristico delle scansioni di porte.

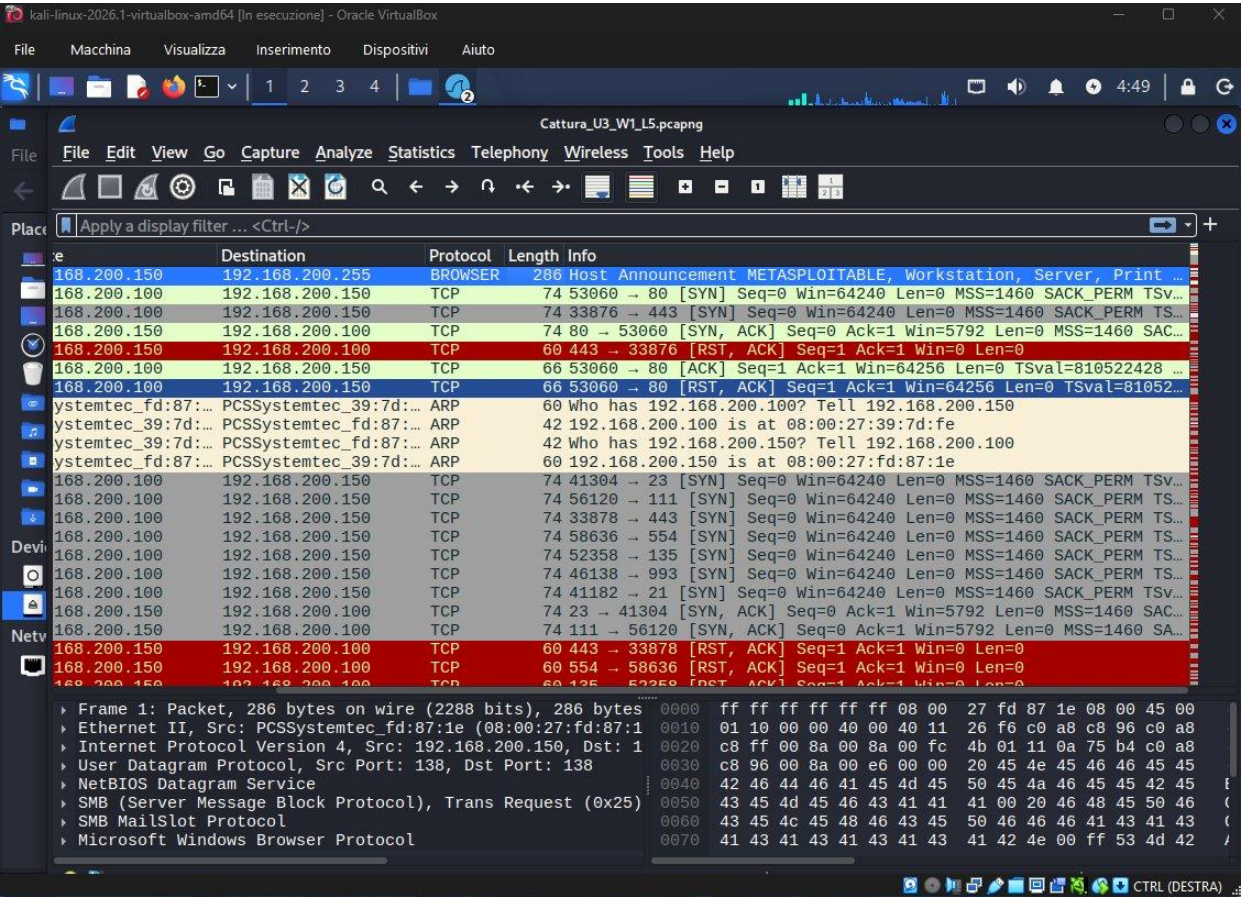


Figura 2 — Vista generale della cattura in Wireshark: si notano i pacchetti RST-ACK (rosso) e il traffico SYN verso molteplici porte

3.2 Il Three-Way Handshake TCP — Breve Richiamo

Per capire bene cosa sta succedendo nella cattura, è necessario fare un passo indietro e ricordare come funziona il meccanismo di connessione TCP, il cosiddetto three-way handshake (o handshake a tre vie). Ammetto che la prima volta che ho studiato questo meccanismo mi sembrava un po' astratto, ma guardando una cattura reale tutto diventa molto più chiaro.

Quando un client vuole stabilire una connessione TCP con un server, avviene questa sequenza:

- SYN: il client invia un pacchetto con il flag SYN (synchronize) attivato, indicando la propria intenzione di aprire una connessione e il proprio numero di sequenza iniziale.
- SYN-ACK: il server, se la porta è aperta e accetta connessioni, risponde con un pacchetto in cui sono attivi sia il flag SYN che il flag ACK (acknowledge). Questo significa: 'ho ricevuto la tua richiesta, sono pronto, ecco il mio numero di sequenza'.
- ACK: il client conferma la ricezione con un pacchetto ACK. A questo punto la connessione è stabilita e si possono scambiare dati.

Se invece la porta di destinazione è chiusa, il server risponde con un pacchetto RST-ACK (reset), che equivale a dire: 'non c'è nessuno qui, vai via'. Questo comportamento differenziato — SYN-ACK per le porte aperte, RST-ACK per quelle chiuse — è esattamente ciò che viene sfruttato durante una port scan, come vedremo nel prossimo paragrafo.

3.3 Identificazione degli IOC

3.3.1 IOC #1 — Port Scan TCP Connect su 1024 Porte

L'indicatore più evidente e immediato che emerge dall'analisi della cattura è un massiccio port scanning TCP. Osservando i pacchetti, noto che l'host 192.168.200.100 invia pacchetti SYN verso 192.168.200.150 su un numero elevatissimo di porte di destinazione diverse, tutte nell'intervallo 1-1024, in un arco di tempo estremamente compresso (meno di un secondo per le porte dalla 21 in poi). Nessun utente umano potrebbe aprire manualmente centinaia di connessioni TCP in questo modo: il comportamento è chiaramente automatizzato.

Per isolare con precisione le porte che hanno risposto positivamente, ho applicato in Wireshark il filtro che esclude i pacchetti RST e i SYN puri, mostrando solo i pacchetti ACK puri — quelli che confermano l'avvenuto completamento del handshake, ovvero le porte effettivamente aperte:

```
tcp.flags.syn == 0 && tcp.flags.ack && tcp.flags.reset == 0
```

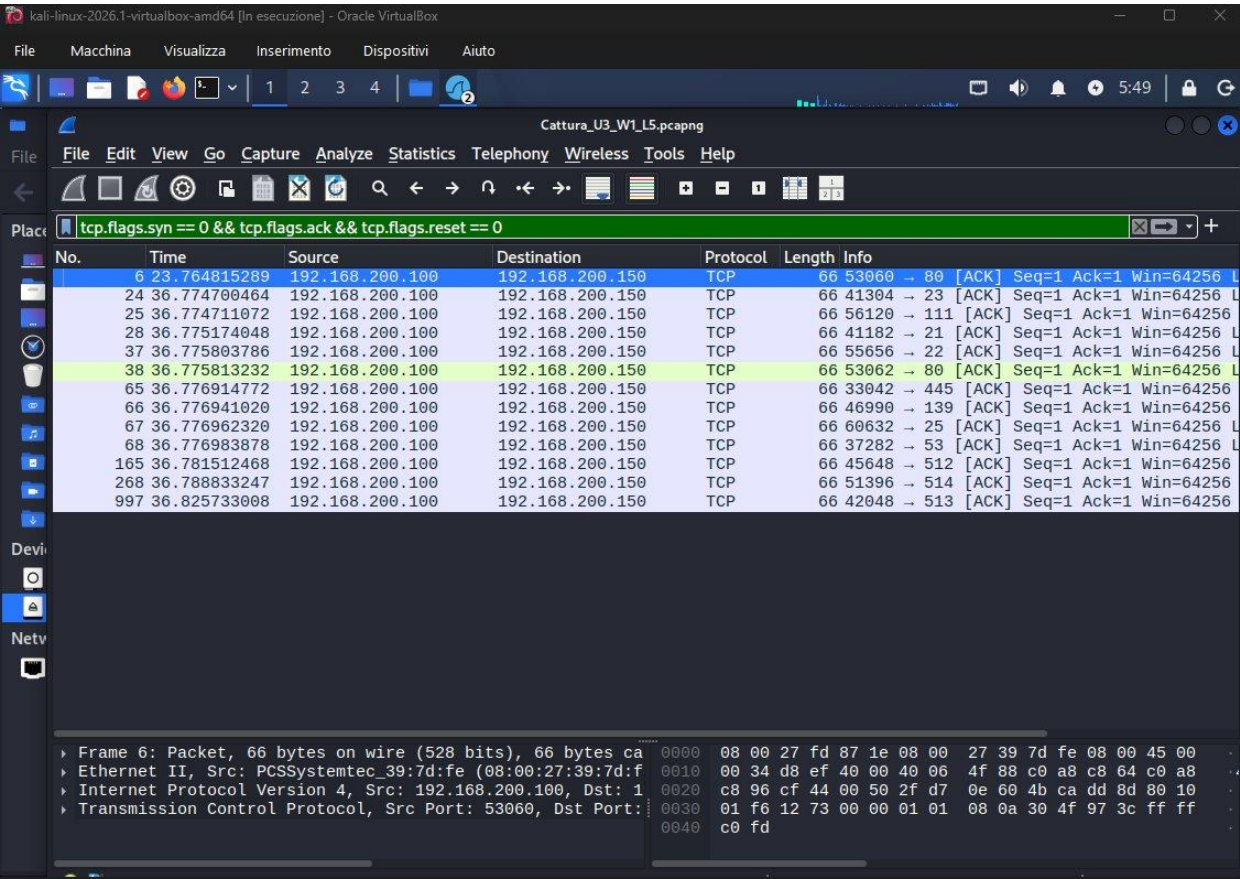



Figura 3 — Filtro Wireshark applicato per isolare i pacchetti ACK puri: ogni riga corrisponde a una porta aperta confermata

Applicando questo filtro, è possibile identificare con precisione quali porte hanno risposto con SYN-ACK, ovvero quali erano effettivamente aperte al momento della scansione:

Porta	Servizio	Note
21	FTP	File Transfer Protocol — autenticazione spesso in chiaro
22	SSH	Secure Shell — accesso remoto
23	Telnet	Accesso remoto in chiaro — altamente vulnerabile
25	SMTP	Mail server
53	DNS	Domain Name System
80	HTTP	Web server
111	RPC/portmapper	Remote Procedure Call — spesso vettore di exploit
139	NetBIOS	Condivisione file Windows/Samba
445	SMB	Server Message Block — Samba, vettore noto (EternalBlue, ecc.)

Porta	Servizio	Note
512	rexec	Remote exec — servizio Unix legacy non sicuro
513	rlogin	Remote login — nessuna cifratura
514	rsh	Remote shell — nessuna autenticazione

Figura 4 — Porte aperte identificate tramite risposta SYN-ACK

La presenza simultanea di tutti questi servizi aperti su un unico host è già di per sé un indicatore significativo: si tratta chiaramente di Metasploitable 2, una macchina Linux deliberatamente vulnerabile usata in laboratorio, ma che in un contesto reale rappresenterebbe un sistema gravemente esposto.

3.3.2 IOC #2 — Pattern Temporale della Scansione

Un secondo IOC, strettamente correlato al primo, è il pattern temporale con cui vengono inviati i pacchetti SYN. Analizzando i timestamp della cattura, si osserva che a partire da circa il secondo 36.774 si ha una vera e propria raffica di tentativi di connessione verso porte diverse: alcune decine di connessioni vengono tentate nell'arco di poche centinaia di millisecondi. Questo pattern — che Wireshark rende immediatamente visibile grazie alla colonna Time — è incompatibile con qualsiasi traffico legittimo generato da un utente o da un'applicazione normale. Il primo tentativo verso la porta 80 avviene attorno al secondo 23.764, mentre l'ondata principale di scansioni sulle porte 21-1024 inizia attorno al secondo 36.774 e termina intorno al secondo 36.878, per una durata complessiva di circa 104 millisecondi.

3.3.3 IOC #3 — Host Announcement NetBIOS

Un terzo elemento degno di nota è la presenza di un pacchetto di tipo Browser Protocol — Host Announcement emesso da 192.168.200.150 verso l'indirizzo broadcast 192.168.200.255. Questo pacchetto, catturato come primo frame della sessione, annuncia la presenza dell'host METASPLOITABLE sulla rete, insieme ai suoi servizi (Workstation, Server, Print Server). Dal punto di vista dell'intelligence, questo tipo di traffico è una fonte passiva di informazioni per un attaccante: semplicemente stando in ascolto sulla rete, è possibile enumerare gli host presenti e i loro ruoli senza inviare alcun pacchetto.

3.4 Correlazione degli IOC con il Vettore di Attacco

Mettendo insieme i tre IOC identificati, il quadro che emerge è abbastanza chiaro: ci troviamo nella fase di ricognizione attiva (reconnaissance) di un attacco strutturato secondo il modello Cyber Kill Chain o, in termini MITRE ATT&CK, nella tattica Discovery con la tecnica Network Service Scanning (T1046). Il comando nmap che ipotizzo sia stato utilizzato per generare questo traffico è il seguente:

```
nmap -sT -p 1-1024 192.168.200.150
```

L'opzione -sT indica una scansione TCP Connect: a differenza del SYN scan stealth (-sS), il TCP Connect completa l'intero three-way handshake per ogni porta aperta, prima di chiudere la connessione con un RST-ACK. Questo spiega la presenza sia di pacchetti SYN-ACK (porte aperte) che di pacchetti RST-ACK (porte chiuse) nella cattura. L'opzione -p 1-1024 limita la scansione alle porte well-known, coerentemente con i dati osservati. Vale la pena notare che la scansione TCP Connect è più 'rumorosa' rispetto ad altri tipi di scan proprio perché completa il handshake: questo la rende più facilmente rilevabile da un IDS/IPS o da uno strumento come Wireshark, ma non richiede privilegi di root sulla macchina attaccante.

4. Ipotesi sui Potenziali Vettori di Attacco

Sulla base dei servizi trovati aperti, è possibile formulare diverse ipotesi sui vettori di attacco che potrebbero essere sfruttati in una fase successiva. La port scan rappresenta tipicamente il preludio a tentativi di exploitation mirati: l'attaccante usa le informazioni raccolte per scegliere quale vulnerabilità provare ad exploitare.

4.1 Vettori ad Alto Rischio

I servizi legacy aperti sulle porte 512 (rexec), 513 (rlogin) e 514 (rsh) rappresentano forse i vettori di rischio più immediati. Questi protocolli Unix erano stati progettati in un'epoca in cui la sicurezza di rete non era una priorità, e non implementano né cifratura né autenticazione robusta. In ambienti mal configurati, rlogin e rsh permettono l'accesso remoto senza password, basandosi esclusivamente sulla fiducia verso l'indirizzo IP sorgente — un meccanismo banalmente bypassabile con tecniche di spoofing. Analogamente, Telnet sulla porta 23 trasmette tutto il traffico in chiaro, incluse le credenziali di accesso.

La porta 445 (SMB/Samba) è storicamente uno dei vettori più sfruttati: vulnerabilità come CVE-2007-2447 (Samba usermap_script, presente su Metasploitable 2) permettono l'esecuzione remota di codice arbitrario senza autenticazione, direttamente accessibile tramite Metasploit. La porta 111 (portmapper/RPC) può essere usata per enumerare ulteriori servizi RPC in ascolto sul sistema, fornendo all'attaccante una mappa ancora più dettagliata dei servizi disponibili.

4.2 Catena di Attacco Ipotetica

Uno scenario di attacco realistico, basato sugli IOC identificati, potrebbe seguire questa progressione: dopo la ricognizione con nmap (già documentata dalla nostra cattura), l'attaccante potrebbe sfruttare la vulnerabilità Samba CVE-2007-2447 per ottenere una shell remota con privilegi di root, oppure potrebbe tentare un attacco di brute force su SSH (porta 22) con strumenti come Hydra. Una volta ottenuto l'accesso iniziale, i servizi rsh/rlogin aperti faciliterebbero il movimento laterale verso altri sistemi eventualmente presenti nella rete.

5. Raccomandazioni di Mitigazione

5.1 Azioni Immediate

La prima azione da intraprendere, con carattere di urgenza, è il blocco del traffico proveniente dall'host 192.168.200.100 a livello di firewall o ACL di rete. In uno scenario reale sarebbe imperativo isolare immediatamente la sorgente del traffico sospetto per evitare che la fase di ricognizione si trasformi in exploitation attiva.

- Blocco immediato di 192.168.200.100 tramite regola firewall (iptables, pf o equivalente).
- Analisi dei log di accesso sui servizi aperti per verificare se la fase di reconnaissance sia già stata seguita da tentativi di login o exploitation.
- Alert al team SOC o al responsabile della sicurezza per avviare un'indagine formale.

5.2 Hardening del Sistema Target

Sul sistema 192.168.200.150, o su qualsiasi sistema di produzione con un profilo simile, è indispensabile ridurre drasticamente la superficie di attacco. I servizi legacy come rsh, rlogin e rexec non dovrebbero mai essere esposti su una rete non fidata e dovrebbero essere disabilitati del tutto in favore di alternative sicure come SSH. Telnet dovrebbe essere sostituito da SSH su tutti i sistemi. FTP andrebbe rimpiazzato da SFTP o FTPS. Il servizio Samba deve essere aggiornato all'ultima versione disponibile e configurato con autenticazione robusta, limitando l'accesso alle sole share necessarie.

5.3 Difesa in Profondità e Prevenzione Futura

Per prevenire il successo di attacchi simili in futuro, è fondamentale implementare una strategia di difesa in profondità. A livello di rilevamento, un sistema IDS/IPS (come Suricata o Snort) configurato con regole specifiche per il rilevamento di port scan avrebbe generato un alert per questo traffico in tempo reale. A livello di monitoraggio, l'integrazione dei log di rete in un SIEM (come Splunk o Elastic Stack) permette di correlare eventi su più sistemi. Infine, la segmentazione di rete tramite VLAN riduce il raggio d'azione di un attaccante che riesca ad accedere a un segmento.

Priorità	Azione	Categoria
Alta	Blocco firewall di 192.168.200.100	Risposta immediata
Alta	Disabilitazione rsh/rlogin/rexec/Telnet	Hardening
Alta	Aggiornamento e hardening Samba	Patch Management
Media	Deploy IDS/IPS con regole anti-scan	Detection
Media	Integrazione SIEM per correlazione log	Monitoring
Media	Segmentazione VLAN	Network Security
Bassa	Formazione awareness utenti	Human Factor

Figura 5 — Piano di mitigazione prioritizzato

6. Conclusioni

L'analisi della cattura di rete `Cattura_U3_W1_L5.pcapng` ha permesso di identificare con chiarezza tre indicatori di compromissione principali: una port scan TCP Connect sistematica sulle porte 1-1024, un pattern temporale anomalo incompatibile con traffico legittimo, e la presenza di un Host Announcement NetBIOS che facilita la fase di enumerazione passiva della rete.

Il vettore di attacco ipotizzato è una scansione con il comando `nmap -sT -p 1-1024 192.168.200.150`, che ha permesso all'attaccante di mappare con precisione i servizi esposti sul target. I risultati della scansione rivelano un sistema con una superficie di attacco estremamente ampia, caratterizzata da servizi legacy non sicuri e da vulnerabilità note che potrebbero essere sfruttate con strumenti ampiamente disponibili come Metasploit.

Questo esercizio mi ha aiutato a comprendere concretamente quanto sia importante la fase di monitoring del traffico di rete: ciò che a un primo sguardo sembra traffico TCP normale diventa, sotto l'occhio di Wireshark e con i giusti filtri, la firma inequivocabile di un attacco in corso. La Threat Intelligence non è solo una questione di intelligence feeds e database di IOC: è anche, e soprattutto, la capacità di leggere i dati grezzi e trasformarli in comprensione delle minacce.